

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 1 頁，共 25 頁

單複選題及情境題組題 共 40 題 (佔 100%)

C	1. 針對駭客攻擊手法，下列敘述何者錯誤？ (A) SQL 注入式攻擊 (SQL Injection)：攻擊者會嘗試將惡意 SQL 代碼注入到一個網站的資料庫查詢中，從而獲得未授權的存取權限或提取資料 (B) 跨站腳本攻擊 (Cross-site Scripting, XSS)：攻擊者會將惡意腳本注入到信任的網站中。當其他使用者存取該網站時，他們的瀏覽器會執行這些腳本，可能導致資料洩露 (C) 中間人攻擊 (Man in the middle attack)：這種攻擊包括使用多台電腦 (通常是受感染的，並被攻擊者控制的電腦) 來發起大量的請求，導致竊取偷聽、重新導向通訊 (D) 釣魚攻擊 (Phishing)：攻擊者會偽裝成可信任的實體 (例如銀行或社交媒體網站)，嘗試欺騙使用者透露他們的登錄資訊、信用卡號或其他敏感資訊
A	2. 針對 APT 攻擊 (Advanced Persistent Threat)，下列敘述何者正確？ (A) APT 常用技術手法，如：Privilege Escalation 提權、Lateral Movement 橫向移動 (B) 常見於一般腳本小子 (Script Kiddie) (C) 非針對特定對象之入侵行為 (D) 利用零日漏洞、客製化的惡意軟體，缺點是不具備匿名性與持久性
A B C D 、 A B	3. 下列哪幾種方式是檢測人員執行紅隊演練過程中可能會使用的攻擊手法？ (複選) (A) 在 DMZ 網頁伺服器找到 RCE 漏洞並取得系統控制權，然後在內網進行橫向移動，嘗試取得 Windows Server Active Directory (AD) 的控制權 (B) 透過釣魚信件對企業的海外分公司員工進行社交工

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 2 頁，共 25 頁

C	程，取得員工電腦控制權，然後讀取員工電子郵件信箱，尋找可以拿來利用的機敏資料 (C) 移動到企業所在的樓層，側錄 Wi-Fi 然後嘗試破解密碼，取得企業 Wi-Fi 的存取方式，入侵企業內部網路 (D) 註冊成為企業的供應商，並且利用供應商專用網站造假資料、竄改商品金額，驗證攻擊者可以用更低的價格買進商品
D	4. 【題組 1】情境如附圖所示，依據 NIST SP800 - 30 Guide for Conducting Risk Assessments 文件對於「弱點 (Vulnerability)」之敘述係指「系統安全程序、設計、裝置、或內部控制的一個瑕疵或缺陷，若被利用後，會破壞安全性或違背系統安全政策」。請問關於「弱點」的敘述，下列何項錯誤？ 公司因供應鏈之客戶要求在執行受託業務時，必須針對所承接之受託業務有關的資訊安全有所作為，因此公司高層下令有關人員針對公司在執行受託業務上可能面臨的資訊安全風險議題進行研議。 (A) 微軟發布之 Windows 作業系統漏洞 (B) 系統管理人員依程序於每季末將離職人員之帳號停用 (C) IoT 設備無法變更預設密碼及帳號 (D) 組織內部人員違反資安規定，私自攜帶外接式儲存設備並連接至組織內部重要伺服器使用，進而導致檔案伺服器遭受勒索病毒感染，重要資料遭受加密無法使用
C	5. 【題組 1】情境如附圖所示，依據公司高層的要求，工程師正評估採用「弱點評估」工具來評估公司內部潛在的弱點項目，試問下列有關「弱點評估」之敘述，下列何者「有誤」？ 公司因供應鏈之客戶要求在執行受託業務時，必須針對所承接之受託業務有關的資訊安全有所作為，因此公司高層下令有關人員針對公司在執行受託業務上可能面臨的資訊安全風險議題進行研議。 (A) 可使用 Nessus Professional 工具來進行系統弱點評估 (B) 可使用 Acunetix 工具來進行網站弱點評估 (C) 可使用 Fortify SCA 動態原始碼檢測分析工具來進行軟體

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 3 頁，共 25 頁

	系統之原始碼弱點評估 (D) 可使用 Nmap 工具來進行網路設備弱點評估
A 、 D	6. 【題組 1】情境如附圖所示，工程師在評估使用「弱點評估」工具過程中發現了「通用弱點評分系統（Common Vulnerability Scoring System，CVSS）」的網站，請問下列敘述何項錯誤？ 公司因供應鏈之客戶要求在執行受託業務時，必須針對所承接之受託業務有關的資訊安全有所作為，因此公司高層下令有關人員針對公司在執行受託業務上可能面臨的資訊安全風險議題進行研議。 (A) CVSS 是一個開放的框架，主要用於傳達軟體弱點的特徵以及該弱點的風險程度 (B) CVSS 提供了一種獲取弱點主要特徵並產生回應其嚴重性的數位分數的方法 (C) CVSS 可以將數位分數轉換為定性表示形式（例如低、中、高以及嚴重），來提供組織正確評估其弱點管理流程並確定其處裡弱點的優先順序 (D) CVSS 由基本度量組（Base metric groups）、時間度量組（Temporal metric groups）以及環境度量組（Environmental metric groups）等三個部分所組成
A B C	7. 【題組 1】情境如附圖所示，工程師使用了弱點掃描軟體來針對公司內部系統進行掃描後，發現了弱點掃描軟體原生報告內指出公司的系統具有一個「CVE-2022-26809 Remote Procedure Call Runtime Remote Code Execution Vulnerability」嚴重風險程度的弱點，攻擊者可將特別製作之遠端程序呼叫（Remote Procedure Call，RPC）傳送至 RPC 主機，即可獲得與 RPC 服務相同之權限，進而於伺服器上遠端執行任意程式碼，該工程師為了處理這個弱點，因此採取了一些的措施來因應，試問採用下列哪些措施較為合適？（複選） 公司因供應鏈之客戶要求在執行受託業務時，必須針對所承接之受託業務有關的資訊安全有所作為，因此公司高層下令有關人員針對公司在執行受託業務上可能面臨的資訊安全風險議題進行研議。 (A) 連接 CVE 網站（https://cve.mitre.org/）檢視該弱點的詳

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 4 頁，共 25 頁

	細資訊 (B) 連接微軟官網下載針對此弱點所發布之安全更新程式予以修補 (C) 在防火牆上採取阻擋 TCP 埠 445 的緩解措施 (D) 將所有主機系統變更為 Unix Base
C	8. 有關 NIST 網路安全框架（Cybersecurity Framework，CSF）所參考適用於 IT 與 OT 環境之國際標準或指引。下列敘述何者錯誤？ (A) ISO/IEC 27001：2013 (B) ISA 62443-2-1：2009 (C) NIST SP 800-72 (D) ISA 62443-3-3：2013
C、B	9. 關於 OWASP（Cyber Defense Matrix，CDM）網路防禦矩陣基本結構的敘述，下列何者錯誤？ (A) 網路防禦矩陣（Cyber Defense Matrix, CDM）可協助企業的整體資安綜合防護評估更有邏輯與結構 (B) 矩陣基本結構可區分為 NIST 網路安全框架（Cybersecurity Framework，CSF）的五個功能以及以資產類別為主的兩個維度 (C) NIST 網路安全框架（Cybersecurity Framework，CSF）之框架核心（Framework Core）的五個功能維度包含識別（Identify）、保護（Protect）、偵測（Detect）、回應（Respond）與資產管理（Asset Management） (D) 資產類別維度包含設備（Devices）、應用程式（Application）、網路（Network），資料（Data）與人員（User）
C、B	10. 機關對外服務網站無法正常提供服務，經分析 DNS 遭受混合式 DDoS 攻擊，下列建議之 DDoS 防護措施何者最「不」合適？

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 5 頁，共 25 頁

	(A) 可透過採購網路流量清洗服務，來緩解 DDoS 攻擊 (B) 可透過限制 DNS 查詢次數，來緩解 DDoS 攻擊 (C) 如果網路頻寬無須考量，可使用過濾機制來緩解 DDoS 攻擊 (D) 可透過避免成為 Open Resolver 來緩解 DDoS 攻擊
B	11. 如附圖所示，駭客透過某機關網頁上傳功能漏洞植入 APT 惡意程式，並嘗試取得系統資料，恐有資料外洩之虞。下列建議之防範措施何者最「不」合適？ (A) 機關建立資通安全威脅偵測管理機制 (B) 為落實軟體及資訊完整性防護，上傳檔案不限格式且一律透過防毒軟體告警 (C) 對於目錄進行完整性監控及驗證，即時偵測目錄異動行為 (D) 辦理服務安全性檢測作業時，可評估採多家廠商交互驗證為宜
A	12. 對於一家正準備進行採購網站應用程式的公司來說，為什麼應該以自動化漏洞評估系統（Automated Vulnerability Assessment System，AVAS）作為驗收基礎，而不是根據開放式網路應用安全項目（Open Web Application Security Project，OWASP）Top 10 的 10 大弱點項目作為驗收要件？ (A) OWASP Top 10 僅涵蓋最常見的安全漏洞，而不是所有可能的安全問題 (B) OWASP Top 10 較易於實施且成本更低 (C) AVAS 獲得領導者向象中的指標意義 (D) AVAS 僅針對網站應用程式，而 OWASP Top 10 適

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 7 頁，共 25 頁

	(B) 設定「密碼歷程記錄」的原則為了方便使用者自己找到以前使用過的密碼 (C) 設定「密碼最短使用效期」的原則是指該密碼必須使用一段時間後才能再次進行變更，通常是配合密碼歷程機制啟用 (D) 「圖形驗證碼」是設計一組對人類能夠輕易回答而對電腦是困難的題目，以作為區分執行動作的是電腦還是人類的行為
D	15. 【題組 2】情境如附圖所示。請問下列何項防禦改善措施跟本次事件的起因「較無直接關連」？ 你在一間上市櫃公司上班，上個月公司忽然遇到重大資安事件，起因是有同仁點擊釣魚信件，該釣魚信件並未被郵件閘道伺服器（Mail Gateway）攔截，同時筆電的防毒軟體也沒有更新，導致該筆電被攻擊者控制。後來該台筆電成為攻擊者的跳板，並且攻擊者持續在內部進行橫向移動，最後取得核心系統跟機敏資料的控制權。在事件發生後，主管請你制訂後續的改善計畫。 (A) 定期對員工進行教育訓練及案例說明，提升員工的資安意識，降低員工點擊釣魚信件的機率 (B) 確保每一台端點都安裝防毒軟體與 EDR 軟體並且定期更新，提升端點設備對抗惡意程式的能力 (C) 定期確認郵件閘道伺服器（Mail Gateway）阻擋釣魚信件的防護能力 (D) 定期對公司官網做弱點掃描、源碼檢測、滲透測試
C	16. 【題組 2】情境如附圖所示。2016 年美國銀行當時的首席安全科學家 Sounil Yu 提出了 OWASP CDM (Cyber Defense Matrix)，希望幫助企業盤點目前的防禦機制，並且把盤點結果對應到 NIST CSF 五大類別以及五種企業資產類別。你的主管請你運用 OWASP CDM 的觀念來盤點目前的防禦機制，請問關於 OWASP CDM 描述，下列何項「錯誤」？

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 8 頁，共 25 頁

你在一間上市櫃公司上班，上個月公司忽然遇到重大資安事件，起因是有同仁點擊釣魚信件，該釣魚信件並未被郵件閘道伺服器（Mail Gateway）攔截，同時筆電的防毒軟體也沒有更新，導致該筆電被攻擊者控制。後來該台筆電成為攻擊者的跳板，並且攻擊者持續在內部進行橫向移動，最後取得核心系統跟機敏資料的控制權。在事件發生後，主管請你制訂後續的改善計畫。

- (A) OWASP CDM 的縱軸有五個項目，由上到下包含設備（Devices）、應用程式（Application）、網路（Network）、資料（Data）與人員（User）
- (B) OWASP CDM 的橫軸有五個項目，由左到右包含識別（Identify）、保護（Protect）、偵測（Detect）、回應（Respond）、復原（Recover）
- (C) 在這個 5 乘 5 的矩陣中，橫軸下方有一個區域標示了依賴程度，依賴程度有三個考量因素，包含科技（Technology）、人員（People）、流程與治理（Process/Govern），其中對於科技（Technology）的依賴程度由左至右是越來越高，對於人員（People）的依賴程度由左至右是越來越低
- (D) OWASP CDM 主要用來分類資安產品與服務所對應到的防禦類別，無法用來分析漏洞成因

- A 17. 【題組 2】情境如附圖所示。你開始透過 OWASP CDM 來制訂後續的改善計畫，請問下列何者描述是正確的？

你在一間上市櫃公司上班，上個月公司忽然遇到重大資安事件，起因是有同仁點擊釣魚信件，該釣魚信件並未被郵件閘道伺服器（Mail Gateway）攔截，同時筆電的防毒軟體也沒有更新，導致該筆電被攻擊者控制。後來該台筆電成為攻擊者的跳板，並且攻擊者持續在內部進行橫向移動，最後取得核心系統跟機敏資料的控制權。在事件發生後，主管請你制訂後續的改善計畫。

- (A) 透過資產盤點軟體來瞭解公司內部的電腦數量與作業系統版本並建立清單，屬於識別（Identify）

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 9 頁，共 25 頁

	(B) 確保伺服器所有的 port 都只對有需要存取的來源電腦開放，屬於偵測 (Detect) (C) 開啟更詳盡的日誌紀錄，屬於復原 (Recover) (D) 每個帳號使用唯一的密碼以及使用多因子認證，屬於回應 (Respond)
A D	18. 【題組 2】情境如附圖所示。你的主管對於攻擊者從外網入侵到內網感到很擔憂，想要參考 MITRE ATT&CK 的 Initial Access (初始進入點) 類別來減少外網被入侵的範圍、降低機率，請問關於 MITRE ATT&CK 的描述，下列哪些「錯誤」？(複選) 你在一間上市櫃公司上班，上個月公司忽然遇到重大資安事件，起因是有同仁點擊釣魚信件，該釣魚信件並未被郵件閘道伺服器 (Mail Gateway) 攔截，同時筆電的防毒軟體也沒有更新，導致該筆電被攻擊者控制。後來該台筆電成為攻擊者的跳板，並且攻擊者持續在內部進行橫向移動，最後取得核心系統跟機敏資料的控制權。在事件發生後，主管請你制訂後續的改善計畫。 (A) 只要經常執行弱點掃描、滲透測試，並且積極修補弱點，就不可能發生 Exploit Public-Facing Application (利用對外開放的應用程式) 這類型的問題 (B) 攻擊者經常可以透過 Google Hacking 或是在 GitHub 搜尋企業資料找到 Valid Accounts (有效帳號)，有機會進一步利用這些 Valid Accounts 來登入員工的 VPN 或 Email (C) Supply Chain Compromise (供應鏈攻擊) 有可能發生在商用軟體、開源函式庫、硬體設備上，攻擊來源非常廣泛，因此企業採購軟、硬體時必須對供應鏈進行妥善的監督與管理 (D) Phishing (網路釣魚) 指的是透過 Email 進行釣魚，誘騙使用者點擊附檔來取得設備控制權，目前除了 Email 之外沒有其他媒介或方法可以對使用者進行網路釣魚
A	19. 建置異地或遠距系統的安全連網機制時，請問下列何者通訊安全加密機制規劃較為適當？ (A) 採用對稱式加密機制來處理大量訊息，並使用非對

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 10 頁，共 25 頁

	稱式加密進行金鑰交換 (B) 採用對稱式加密機制來處理大量訊息，並使用數位簽章進行金鑰交換 (C) 採用非對稱式加密機制來處理大量訊息，並使用數位簽章進行金鑰交換 (D) 採用非對稱式加密機制來處理大量訊息，並使用對稱式加密進行金鑰交換
A	20. 關於備份 3-2-1 原則的敘述，下列何者正確？ (A) 已儲存媒體而言，分開存放在兩種不同儲存媒體 (B) 至少三份，分別放到硬碟的 C 槽跟 D 槽 (C) 資料分別存放在辦公室不同樓層 (D) 備份資料不需備份加密金鑰
C	21. 如附圖所示，機關透過威脅情資分享以達到及早預防或應變處理，目前業界針對此等資料交換已發展出多種格式/機制，附圖為惡意程式情資，其所使用格式為下列何項？

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 11 頁，共 25 頁

```
{
  "type": "bundle",
  "id": "bundle--2a25c3c8-5d88-4ae9-862a-cc3396442317",
  "objects": [
    {
      "type": "indicator",
      "spec_version": "2.1",
      "id": "indicator--a932fcc6-e032-476c-826f-cb970a5a1ade",
      "created": "2014-02-20T09:16:08.989Z",
      "modified": "2014-02-20T09:16:08.989Z",
      "name": "File hash for Poison Ivy variant",
      "description": "This file hash indicates that a sample of Poison Ivy is present.",
      "indicator_types": [
        "malicious-activity"
      ],
      "pattern": "[file:hashes.'SHA-256' = 'ef537f25c895bfa782526529a9b63d97aa631564d5d789c2b765448c8635fb6c']",
      "pattern_type": "stix",
      "valid_from": "2014-02-20T09:00:00Z"
    },
    {
      "type": "malware",
      "spec_version": "2.1",
      "id": "malware--fdd60b30-b67c-41e3-b0b9-f01faf20d111",
      "created": "2014-02-20T09:16:08.989Z",
      "modified": "2014-02-20T09:16:08.989Z",
      "name": "Poison Ivy",
      "malware_types": [
        "remote-access-trojan"
      ],
      "is_family": false
    },
    {
      "type": "relationship",
      "spec_version": "2.1",
      "id": "relationship--29dcdf68-1b0c-4e16-94ed-bcc7a9572f69",
      "created": "2020-02-29T18:09:12.808Z",
      "modified": "2020-02-29T18:09:12.808Z",
      "relationship_type": "indicates",
      "source_ref": "indicator--a932fcc6-e032-476c-826f-cb970a5a1ade",
      "target_ref": "malware--fdd60b30-b67c-41e3-b0b9-f01faf20d111"
    }
  ]
}
```

- (A) CybOX
- (B) MAEC
- (C) STIX
- (D) TAXII

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 12 頁，共 25 頁

B	22. 如附圖所示，某機關伺服器管理員於系統例行巡檢時，發現應用程式日誌中出現 “Unauthorized data access attempt” 等告警訊息，下列何者是最優先的應變措施？ <pre>2024-01-10T08:23:45.678Z [INFO] User login: username=admin, IP=192.168.1.10, method=SSH 2024-01-10T08:24:01.123Z [WARNING] Unusual command pattern detected: username=admin, IP=192.168.1.10, command='sudo cat /etc/passwd' 2024-01-10T08:24:05.678Z [INFO] Database query executed: username=admin, query='SELECT * FROM users' 2024-01-10T08:24:10.432Z [ERROR] Unauthorized data access attempt: username=admin, resource='user_credit_card_info' 2024-01-10T08:25:30.789Z [ALERT] Excessive data download by user: username=admin, data=500MB 2024-01-10T08:30:00.001Z [ALERT] Intrusion detection system triggered: IP=192.168.1.12, method=Port Scanning 2024-01-10T08:31:00.789Z [INFO] Firewall rule triggered: rule_id=1005, action=block, IP=192.168.1.12 2024-01-10T08:32:00.456Z [CRITICAL] Multiple failed login attempts: username=root, IP=192.168.1.12 ...</pre> (A) 確定防毒軟體版本 (B) 清查所有管理員帳號使用狀態 (C) 進行全面性的網路安全評估 (D) 更新防火牆規則以阻擋可疑流量
B D	23. H 公司於上周發生公司 email 超過 4 個小時以上無法收發的資安事件，經 MIS 人員處理後發現，郵件伺服器因硬碟空間不足而無法正常運作，並由追蹤相關記錄中找出服務中斷前，系統正在處理一封寄給全公司 2000 位同仁的內部公告郵件，其之中被夾帶著 4GB 的附檔，但此附檔在防毒軟體和沙箱工具檢查後並無病毒或威脅性，刪除此郵件及相關衍生作業後，郵件伺服器恢復正常運作，檢討此次內部資安攻擊事件，確認為人員操作失誤所致。請問下列哪些措施可以防範相關事件再度發生？（複選） (A) 儘快增購郵件伺服器的硬碟容量，避免再發生相同空間不足的問題再度發生 (B) 對員工加強資安教育訓練，避免錯誤的資訊系統操作行為

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 13 頁，共 25 頁

	(C) 增加防火牆檢查細則，減少大量或敏感資料的傳輸與攻擊事件 (D) 郵件伺服器增設郵件處理容量限制，阻絕大檔案的傳送服務
A	24. 【題組 3】情境如附圖所示，特別聘請你擔任資訊安全長一職，首要之務，你必須解決大量的 Log 時間不同步的問題，下列那一個方案能提供最佳成本效益？ 機房管理是安全營運中最為貼近實體安全的議題，在一次的實地查核中，發現有一網站伺服器主機上存有免殺（Anti Anti- Virus）Web shell，安裝於該主機的防毒軟體，並未即時的偵查到該惡意反向連接的 Web shell，資訊安全人員隨即啟動鑑識及調查，發現防火牆上的存取記錄中，每隔一周即有一次來自於外部的記錄。經過過濾 web shell 所在路徑，得到下面的幾個條列記錄，離現今已有半年以上： <pre>Post /bin_file/tmp/resver.php 200 13.137.38.56 admin 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 admin1 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 admin123 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 user 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 manager 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 root 1q2w#ESR Post /bin_file/tmp/resver.php 200 13.137.38.56 sudo 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 jason 1q2w#ESR</pre> 詳細追查該檔案的建立日期為半年前，修改時間為 1 個月前，但在追查相關記錄時發現，外部防火牆上的時間校時為防火牆原廠提供的 NTP（Network Time Protocol），網站應用程式防火牆、外部防火牆及網站主機均有時間誤差。 因公司所有終端電腦及伺服器均加入網域，為有效控制資安事件，鑑識人員追查網域控制站的安全性事件，發現有一管理人員的帳號密碼透過該網站伺服器向網域控制站進行登入，在過去這三個月來，每周均有一次透過網站伺服器主機上的員工入口網站主機登入驗證通過。 同時發現該帳號於網站主機上，安全性事件記錄中，有大量的 4625 事件編號產生，且於網站伺服器的安全性事件中發現在約 2 個月前，已有大量人員的網域帳號因帳號鎖定，需要管理人員解鎖事件發生。 更於上周有員工存放於網路共享磁碟上置放的資料，副檔名變成 encrypt123，CEO 認為這已影響到公司營運。 (A) 將主要網域控制站的 NTP 校時指向國家時間頻率實驗室，並將所有設備 NTP 校時指向主要網域控制站。

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 14 頁，共 25 頁

	(B) 停用硬體內鍵時鐘，更換可採用電波校時的設備 (C) 將不同設備指向不同的 NTP 校時 IP 以分散流量 (D) 將所有設備停用硬體時間，改以定期手動校時
D	25. 【題組 3】情境如附圖所示，發現 Windows 作業系統建置的網站伺服器，該主機上的安全性事件中，查得大量的 4625 事件編號之事件，此事件編號所指的是下列何種事件？ 機房管理是安全營運中最為貼近實體安全的議題，在一次的實地查核中，發現有一網站伺服器主機上存有免殺（Anti Anti- Virus）Web shell，安裝於該主機的防毒軟體，並未即時的偵查到該惡意反向連接的 Web shell，資訊安全人員隨即啟動鑑識及調查，發現防火牆上的存取記錄中，每隔一周即有一次來自於外部的記錄。經過過濾 web shell 所在路徑，得到下面的幾個條列記錄，離現今已有半年以上： <pre>Post /bin_file/tmp/resver.php 200 13.137.38.56 admin 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 admin1 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 admin123 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 user 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 manager 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 root 1q2w#ESR Post /bin_file/tmp/resver.php 200 13.137.38.56 sudo 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 jason 1q2w#ESR</pre> 詳細追查該檔案的建立日期為半年前，修改時間為 1 個月前，但在追查相關記錄時發現，外部防火牆上的時間校時為防火牆原廠提供的 NTP（Network Time Protocol），網站應用程式防火牆、外部防火牆及網站主機均有時間誤差。 因公司所有終端電腦及伺服器均加入網域，為有效控制資安事件，鑑識人員追查網域控制站的安全性事件，發現有一管理人員的帳號密碼透過該網站伺服器向網域控制站進行登入，在過去這三個月來，每周均有一次透過網站伺服器主機上的員工入口網站主機登入驗證通過。 同時發現該帳號於網站主機上，安全性事件記錄中，有大量的 4625 事件編號產生，且於網站伺服器的主機上發現約 2 個月前，已有大量人員的網域帳號因帳號鎖定，需要管理人員解鎖事件發生。 更於上周有員工存放於網路共享磁碟上置放的資料，副檔名變成 encrypt123，CEO 認為這已影響到公司營運。 (A) 帳號登入成功 (B) 帳號被鎖定 (C) 帳號有異動 (D) 帳號登入失敗

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 15 頁，共 25 頁

B	26. 【題組 3】情境如附圖所示，於網站存取 Log 中出現了大量類似密碼的字元“1q2w#ESR”，而前面的欄位中出現了包含 admin, root, jason 等帳號型式的字元，依據這個 log 的內容，以 post 的 http 方法，向/bin_file/tmp/resver.php 傳送了上述的內容，且得到的狀態代碼回應為 200，這種類型的記錄應屬於下列何種攻擊手法？ 機房管理是安全營運中最為貼近實體安全的議題，在一次的實地查核中，發現有一網站伺服器主機上存有免殺（Anti Anti- Virus）Web shell，安裝於該主機的防毒軟體，並未即時的偵查到該惡意反向連接的 Web shell，資訊安全人員隨即啟動鑑識及調查，發現防火牆上的存取記錄中，每隔一周即有一次來自於外部的記錄，經過過濾 web shell 所在路徑，得到下面的幾個條列記錄，離現今已有半年以上： <pre>Post /bin_file/tmp/resver.php 200 13.137.38.56 admin 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 admin1 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 admin123 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 user 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 manager 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 root 1q2w#ESR Post /bin_file/tmp/resver.php 200 13.137.38.56 sudo 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 jason 1q2w#ESR</pre> 詳細追查該檔案的建立日期為半年前，修改時間為 1 個月前，但在追查相關記錄時發現，外部防火牆上的時間校時為防火牆原廠提供的 NTP（Network Time Protocol），網站應用程式防火牆、外部防火牆及網站主機均有時間誤差。 因公司所有終端電腦及伺服器均加入網域，為有效控制資安事件，鑑識人員追查網域控制站的安全性事件，發現有一管理人員的帳號密碼透過該網站伺服器向網域控制站進行登入，在過去這三個月來，每周均有一次透過網站伺服器主機上的員工入口網站主機登入驗證通過。 同時發現該帳號於網站主機上，安全性事件記錄中，有大量的 4625 事件編號產生，且於網站伺服器的安全性事件中發現在約 2 個月前，已有大量人員的網域帳號因帳號鎖定，需要管理人員解鎖事件發生。 更於上周有員工存放於網路共享磁碟上置放的資料，副檔名變成 encrypt123，CEO 認為這已影響到公司營運。 (A) 資料庫注入攻擊 (B) 密碼噴撒攻擊 (C) 跨站台請求偽造 (D) 密碼暴力破解
B	27. 【題組 3】情境如附圖一所示，本次事件範圍廣泛，涵蓋範圍

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 16 頁，共 25 頁

D	除了有網站伺服器主機、網域控制站，而鑑識小組所發現的問題，包含有如附圖二的項目，鑑識小組認為應有網站零日漏洞被利用。請問下列哪 2 項對於員工個人帳號保護最為有效？（複選） 附圖一 機房管理是安全營運中最為貼近實體安全的議題，在一次的實地查核中，發現有一網站伺服器主機上存有免殺（Anti Anti- Virus）Web shell，安裝於該主機的防毒軟體，並未即時的偵查該惡意反向連接的 Web shell，資訊安全人員隨即啟動鑑識及調查，發現防火牆上的存取記錄中，每隔一周即有一次來自於外部的記錄。經過過濾 web shell 所在路徑，得到下面的幾個條列記錄，離現今已有半年以上： <pre>Post /bin_file/tmp/resver.php 200 13.137.38.56 admin 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 admin1 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 admin123 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 user 1q2w#ESR Post /bin_file/tmp/resver.php 200 141.10.213.4 manager 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 root 1q2w#ESR Post /bin_file/tmp/resver.php 200 13.137.38.56 sudo 1q2w#ESR Post /bin_file/tmp/resver.php 200 112.54.117.233 jason 1q2w#ESR</pre> 詳細追查該檔案的建立日期為半年前，修改時間為 1 個月前，但在追查相關記錄時發現，外部防火牆上的時間校時為防火牆原廠提供的 NTP（Network Time Protocol），網站應用程式防火牆、外部防火牆及網站主機均有時間誤差。 因公司所有終端電腦及伺服器均加入網域，為有效控制資安事件，鑑識人員追查網域控制站的安全性事件，發現有一管理人員的帳號密碼透過該網站伺服器向網域控制站進行登入，在過去這三個月來，每周均有一次透過網站伺服器主機上的員工入口網站主機登入驗證通過。 同時發現該帳號於網站主機上，安全性事件記錄中，有大量的 4625 事件編號產生，且於網站伺服器的主機上發現約 2 個月前，已有大量人員的網域帳號因帳號鎖定，需要管理人員解鎖事件發生。 更於上周有員工存放於網路共享磁碟上置放的資料，副檔名變成 encrypt123，CEO 認為這已影響到公司營運。 附圖二 1. 鐘訊未同步，造成受侵害的主機有時戳落差，鑑識時易產生證據時序錯誤。 2. 網站伺服器 Log 中出現類似帳號密碼的猜測行為，但可能尚未找到有效的帳密組合。 3. 網站主機上向網域控制站的安全性事件中，已有某一管理人員帳號外洩，且透過員工入口網登入驗證成功。 4. 員工有大量的帳號鎖定狀況產生。 5. 共用磁碟中出現大量檔案副檔名被變更為 Encrypt123，疑似遭到勒索軟體侵害。 (A) EIP（Enterprise Information Portal）系統應限定僅有內部 IP 得以連接
---	---

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 17 頁，共 25 頁

	(B) 密碼破解類的字典檔攻擊，應宣導加長密碼長度以提升帳號安全 (C) 導入 SOC (Security Operation Center) 機制使入侵行為即早得到預警 (D) 應導入多因子身份驗證以維護其安全
B C	28. 網路安全滲透測試的目標包括一切與網路相關的基礎設施，包含網路裝置、作業系統、實體安全、應用程式、管理制度等。下列敘述哪些錯誤？（複選） (A) 網路裝置是包含所有能夠連接到網路的各種實體，像是路由器、交換機、防火牆、個人電腦等 (B) 實體安全主要指的是機房環境、通訊設備等，是資訊安全中最重要的目標 (C) 應用程式是管理與控制電腦軟硬體資源的電腦程式 (D) 管理制度指的是為了保障網路安全對使用者提出的要求與限制
C	29. 關於滲透測試工具的敘述，下列何者正確？ (A) John the Ripper 和 Hashcat，主要用在社交工程 (B) Aircrack-ng 和 Kismet 用在有線網路刺探分析 (C) Nmap 和 Wireshark 用於識別網路中的設備，以及他們開放的端口和服務 (D) OWASP ZAP 和 Burp Suite 用在作業系統漏洞分析
C	30. Metasploit 框架最主要是用於下列何種情境？ (A) 防火牆配置 (B) 網路封包分析 (C) 漏洞利用和測試 (D) 垃圾郵件過濾
C	31. 如附圖所示，關於 PTES (Penetration Testing Execution Standard) 流程項目的排序，下列何者正確？

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 18 頁，共 25 頁

	1.漏洞分析（Vulnerability Analysis） 2.威脅建模（Threat Modeling） 3.報告（Reporting） 4.後期利用（Post Exploitation） 5.利用（Exploitation） 6.情報收集（Intelligence Gathering） 7.前期溝通（Pre-engagement Interactions） (A) 漏洞分析 > 威脅建模 > 情報收集 > 報告 (B) 情報收集 > 漏洞分析 > 威脅建模 > 報告 (C) 前期溝通 > 情報收集 > 漏洞分析 > 報告 (D) 威脅建模 > 前期溝通 > 情報收集 > 漏洞分析
A B	32. 在進行網站檢查時，發現其未設定 HTTP Strict Transport Security (HSTS) 標頭，請問下列敘述那些較為適切？（複選） (A) 可能遭受中間人攻擊（Man-in-the-Middle，MITM） (B) 可能遭受 SSLStrip 攻擊 (C) 可於網站伺服器中停用 Port 80 的服務來修補這問題 (D) 可於網站伺服器中停用 Port 443 的服務來修補這問題
B	33. 【題組 4】情境如附圖所示。根據所發現的原始碼，除發現 logLoginAttemp 函數未實做而可能有 OWASP A09:2021-Security Logging and Monitoring Failures 風險，還有下列何項 OWASP Top 10:2021 風險最可能存在？

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 19 頁，共 25 頁

你正在協助產品開發單位，對即將上線的電子商務網站進行安全測試，並且於測試過程中發現一份 JavaScript 原始碼片段（如下圖），請指出這份原始碼所可能含有的安全問題並提供適當修補建議。

```
// Advanced eCommerce Website User Login JavaScript Code
function authenticateUser(username, password) {
  const query = "SELECT * FROM users WHERE username = '" + username + "' AND password = '" + password + "'";
}

function logLoginAttempt(username, success) {
  // Log login attempt, including username and success/failure
}

app.post('/login', function(req, res) {
  let username = req.body.username;
  let password = req.body.password;
  let isAuthenticated = authenticateUser(username, password);

  logLoginAttempt(username, isAuthenticated);
  if (isAuthenticated) {
    res.send('Login successful!');
  } else {
    res.send('Login failed!');
  }
});

function verifyToken(token) {
  // Verify the token's validity
}

app.post('/api/protected', function(req, res) {
  let token = req.headers.authorization;
  if (!verifyToken(token)) {
    res.status(401).send('Unauthorized');
    return;
  }
  // Protected API logic here
});
```

- (A) A02:2021-Cryptographic Failures
- (B) A03:2021-Injection
- (C) A05:2021-Security Misconfiguration
- (D) A06:2021-Vulnerable and Outdated Components

B 34. 【題組 4】情境如附圖所示。根據所發現的原始碼，verifyToken 函數若要實做安全檢查機制，下列何項措施最合適？

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 20 頁，共 25 頁

你正在協助產品開發單位，對即將上線的電子商務網站進行安全測試，並且於測試過程中發現一份 JavaScript 原始碼片段（如下圖），請指出這份原始碼所可能含有的安全問題並提供適當修補建議。

```
// Advanced eCommerce Website User Login JavaScript Code
function authenticateUser(username, password) {
  const query = "SELECT * FROM users WHERE username = '" + username + "' AND password = '" + password + "'";
}

function logLoginAttempt(username, success) {
  // Log login attempt, including username and success/failure
}

app.post('/login', function(req, res) {
  let username = req.body.username;
  let password = req.body.password;
  let isAuthenticated = authenticateUser(username, password);

  logLoginAttempt(username, isAuthenticated);
  if (isAuthenticated) {
    res.send('Login successful!');
  } else {
    res.send('Login failed!');
  }
});

function verifyToken(token) {
  // Verify the token's validity
}

app.post('/api/protected', function(req, res) {
  let token = req.headers.authorization;
  if (!verifyToken(token)) {
    res.status(401).send('Unauthorized');
    return;
  }
  // Protected API logic here
});
```

- (A) 檢查 token 的時間戳記
- (B) 驗證 token 的簽章
- (C) 確認 token 的使用者角色
- (D) 檢查 token 的來源 IP

- C 35. 【題組 4】情境如附圖所示。根據所發現的原始碼，如要降低 /api/protected 路徑潛在漏洞而危害資料安全，下列何項措施何者最合適？

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 21 頁，共 25 頁

你正在協助產品開發單位，對即將上線的電子商務網站進行安全測試，並且於測試過程中發現一份 JavaScript 原始碼片段（如下圖），請指出這份原始碼所可能含有的安全問題並提供適當修補建議。

```
// Advanced eCommerce Website User Login JavaScript Code
function authenticateUser(username, password) {
  const query = "SELECT * FROM users WHERE username = '" + username + "' AND password = '" + password + "'";
}

function logLoginAttempt(username, success) {
  // Log login attempt, including username and success/failure
}

app.post('/login', function(req, res) {
  let username = req.body.username;
  let password = req.body.password;
  let isAuthenticated = authenticateUser(username, password);

  logLoginAttempt(username, isAuthenticated);
  if (isAuthenticated) {
    res.send('Login successful!');
  } else {
    res.send('Login failed!');
  }
});

function verifyToken(token) {
  // Verify the token's validity
}

app.post('/api/protected', function(req, res) {
  let token = req.headers.authorization;
  if (!verifyToken(token)) {
    res.status(401).send('Unauthorized');
    return;
  }
  // Protected API logic here
});
```

- (A) 提升使用者密碼複雜度設定規則
- (B) 實做網路層的防火牆保護
- (C) 對 API 回應適當的去機敏資料處理
- (D) 執行用戶端行為分析和異常檢測

- A 36. 【題組 4】情境如附圖所示。在你執行完安全檢測並提供相關建議
B 後，開發團隊對程式進行弱點修補並強化了 logLoginAttempt 函數
D 如圖 1，下列哪些描述正確？（複選）

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 22 頁，共 25 頁

你正在協助產品開發單位，對即將上線的電子商務網站進行安全測試，並且於測試過程中發現一份 JavaScript 原始碼片段（如下圖），請指出這份原始碼所可能含有的安全問題並提供適當修補建議。

```
// Advanced eCommerce Website User Login JavaScript Code
function authenticateUser(username, password) {
  const query = "SELECT * FROM users WHERE username = '" + username + "' AND password = '" + password + "'";
}

function logLoginAttempt(username, success) {
  // Log login attempt, including username and success/failure
}

app.post('/login', function(req, res) {
  let username = req.body.username;
  let password = req.body.password;
  let isAuthenticated = authenticateUser(username, password);

  logLoginAttempt(username, isAuthenticated);
  if (isAuthenticated) {
    res.send('Login successful!');
  } else {
    res.send('Login failed!');
  }
});

function verifyToken(token) {
  // Verify the token's validity
}

app.post('/api/protected', function(req, res) {
  let token = req.headers.authorization;
  if (!verifyToken(token)) {
    res.status(401).send('Unauthorized');
    return;
  }
  // Protected API logic here
});
```

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 23 頁，共 25 頁

附圖 1

```
// Extended logLoginAttempt function with secure implementations
function logLoginAttempt(username, success, ipAddress) {
  let timestamp = new Date().toISOString();
  let logMessage = `Timestamp: ${timestamp}, Username: ${username}, Success: ${
    success}, IP: ${ipAddress}`;

  // Code to log the message to a file or database
  console.log(logMessage);
  fs.writeFile('/public/logs/loginAttempts.txt', logMessage, { flag: 'a+' },
    err => {
      if (err) {
        console.error('Logging error: ', err);
      }
    });

  // Emailing log details
  emailService.sendEmail('admin@example.com', 'Login Attempt Logged',
    logMessage);

  // Additional logic to analyze login attempts and detect anomalies
  (potentially secure)
  // ...
}
```

- (A) 記錄 IP 位置有助於識別和追蹤嘗試惡意登入的來源
- (B) 使用 ISO 8601 的時間格式有利於分析，可紀錄一致且標準化的時間資訊
- (C) 日誌記錄於瀏覽器主控台或可公開存取檔案，為兼顧安全與可用性的實做方式
- (D) 此函數能夠協助系統管理者識別帳號枚舉攻擊與試圖暴力破解之行為

- B 37. 【題組 5】情境如附圖所示。第三方套件供應商提交了一份源碼檢測報告，報告內容僅顯示受測軟體的版本、程式碼的行數、受測主件檔案的雜湊值，你發現報告中完全查無任何弱點，連資訊等級的弱點都沒有，你該如何向甲方證明所採用的套件在當下是安全無虞？

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 24 頁，共 25 頁

你是一間跨國企業的資安管理人員，你每一年都必須針對集團、子集團進行安全檢測與合規要求的驗證，在台灣由於集團參與了我國 A 級機關的軟體開發案，你必須針對組織的流程及服務進行合規的證明，你目前必須完成的包含有核心系統的滲透測試、採購的第三方套件商提供的源碼檢測報告及協助集團提交主要服務的系統開發流程的相關資安證明。

- (A) 請第三方套件供應商再提供一份其它檢測報告
- (B) 請第三方套件供應商提交一份源碼檢測的歷程報告
- (C) 直接交付第三方套件供應商提交的源碼檢測報告給甲方
- (D) 自己針對第三方套件進行黑箱檢測並撰寫報告提交於甲方

- C 38. 【題組 5】情境如附圖所示。滲透測試的外包商在進行檢測時，發現網站根目錄下存在不少的 PHP 檔案，例如有 1111.PHP, Shell.php, probe.php 還發現了一些副檔名為.dump 的檔案，其中有一個檔案開啟後如附圖一所示。請問此檔案為下列何項？

你是一間跨國企業的資安管理人員，你每一年都必須針對集團、子集團進行安全檢測與合規要求的驗證，在台灣由於集團參與了我國 A 級機關的軟體開發案，你必須針對組織的流程及服務進行合規的證明，你目前必須完成的包含有核心系統的滲透測試、採購的第三方套件商提供的源碼檢測報告及協助集團提交主要服務的系統開發流程的相關資安證明。

附圖一

```
SMB 192.168.0.76 445 DC [*] Windows Server 2012 R2 Standard 9600 x64 (name:DC) (domain:test
.lab) (signing:True) (SMBv1:True) SMB 192.168.0.76 445 DC [+] test.lab\testadmin:Password12
3 (Pwn3d!) SMB 192.168.0.76 445 DC [+] Dumping LSA secrets SMB 192.168.0.76 445 DC TEST\DC$:
aes256-cts-hmac-sha1-96:5a0f8706487aae9bf38161a4608e7567ac1c4a105226b783ccbd98274c8d4018 SM
B 192.168.0.76 445 DC TEST\DC$:aes128-cts-hmac-sha1-96:d8402dda8272520b01ba6b8dcfd9b3d8 SMB
192.168.0.76 445 DC TEST\DC$:des-cbc-md5:f45b2361ae1ad308 SMB 192.168.0.76 445 DC TEST\DC$:
plain_password_hex:4e4545a05fe307150e0679cf4169caea359467422908fec7e82b6eb63d23dfa9cb180c4c
3da62ff7ce1ab1396b1fa505300bed8d7a67e36b74ab9b25721756181c47850cf9dc220964ae7c50a104cfed776
f5c1cb8865bb443d9d757cd90dc1dca063ba89776825f20d7d61b7debf5339cd69dc3c3c81b0e81c6b74065d44
56a6339991fd05a5e687cd8fd0f81562a3613f7094015ab82ca0e16fca01551fdef5f397f48664cb64801215b45
3d29c1034aca75242c3be6aa080dd6be94ca91f712db8c6d4ca6305ee47912fa5a11bc388388fde380c3d9a712d
6c8fe36b50c3cdedc4cae98d75eb9561c0a8ec13a0da SMB 192.168.0.76 445 DC TEST\DC$:aad3b435b5140
4eeaad3b435b51404ee:6e93dbc1944a24129c85324692f4687b::: SMB 192.168.0.76 445 DC dpapi_machi
nekey:0x974d7e0eab71f962c006ae631a67883cb65fbb8e dpapi_userkey:0xcc3bd3a27097b37446adc6e7dc
5023a3316e3a3e SMB 192.168.0.76 445 DC NL$KM:b4d3d7354ecec7c5d18ca62845d33e65cdaf826db03b4bf
401f2c3864fd56d271f908f8eefbf0d278675be217810199c6ce158550484b62fd6a280564bf305814 SMB 192.
168.0.76 445 DC [+] Dumped 7 LSA secrets to /home/t/.cme/logs/DC_192.168.0.76_2021-07-22_12
2314.secrets and /home/t/.cme/logs/DC_192.168.0.76_2021-07-22_122314.cached
```

- (A) 這是偵錯的 log 檔案
- (B) 這是登入成功、失敗的安全性事件

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：113 年 08 月 10 日

第 25 頁，共 25 頁

	(C) 這是 CRACKMAPEXEC 分析密碼的結果檔 (D) 這是 mimikatz 另存出來的結果檔
B	39. 【題組 5】情境如附圖所示。當資料查核到資料庫時，發現資料庫有很大量的合規要求都沒有做到，但要調整設定必須在不影響資料庫的運作的前提下，確認資料庫是否安全，可以透過下列何種方法進行初步的驗證最為合適？ 你是一間跨國企業的資安管理人員，你每一年都必須針對集團、子集團進行安全檢測與合規要求的驗證，在台灣由於集團參與了我國 A 級機關的軟體開發案，你必須針對組織的流程及服務進行合規的證明，你目前必須完成的包含有核心系統的滲透測試、採購的第三方套件商提供的源碼檢測報告及協助集團提交主要服務的系統開發流程的相關資安證明。 (A) 以應用程式弱點檢測報告提交 (B) 以資安健檢的資料庫安全健檢提交報告 (C) 以滲透測試報告提交報告 (D) 提交一份主機弱點檢測報告
A B D	40. 【題組 5】情境如附圖所示。作為跨國企業的資安管理人員，您在進行核心系統滲透測試時發現了外部系統曾被惡意攻擊，並留下攻擊殘餘的指令碼。下列哪些安全風險及處理的描述較為適當？（複選） 你是一間跨國企業的資安管理人員，你每一年都必須針對集團、子集團進行安全檢測與合規要求的驗證，在台灣由於集團參與了我國 A 級機關的軟體開發案，你必須針對組織的流程及服務進行合規的證明，你目前必須完成的包含有核心系統的滲透測試、採購的第三方套件商提供的源碼檢測報告及協助集團提交主要服務的系統開發流程的相關資安證明。 (A) 系統存在未修補的漏洞，需要立即更新 (B) 需要對系統進行更深入的檢視 (C) 需要增強員工對釣魚攻擊和社交工程的警覺性 (D) 應該檢查並更新防火牆和入侵檢測系統的配置